

ET 8202:

INTRODUCTION TO IS

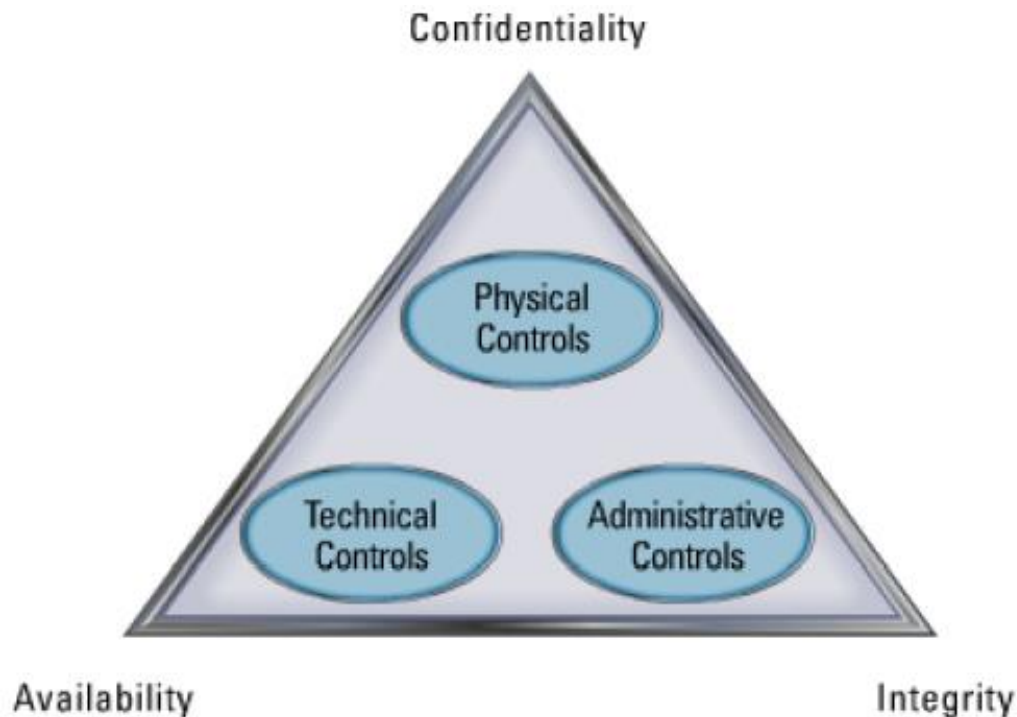
SECURITY

LECTURE 05

Access Controls (a)

Controls

- ❖ The goal of security management is to protect the company's assets.
- ❖ Security has three main objectives (CIA Triad)
- ❖ Controls are required in order to achieve CIA



Access Control

- ❖ *Access control is a process to determine “Who does what to what,” based on a policy.*
- ❖ It is controlling access of who gets in and out of the system and who uses what resources, when, and in what amounts (or to which extent).
 - ❖ Who can access what, when + how (to which extent).
- ❖ Access control is restricting access to a system or system resources based on something other than the identity of the user.
 - ❖ Access is restricted based on more factors apart from user's identity.

Access Control

❖ Security management utilizes three control types to protect the assets:

1. Administrative controls

- These are controls that include the **development and publication** of security **policies, standards, procedures, personnel screening**, system activity monitoring, change control procedures, and security awareness training.

2. Technical controls

- These are controls that consist of logical access control mechanisms, password and resource management, identification and authentication methods, configuration of the network and relevant security devices.

3. Physical controls

- These are controls that include controlling individual access into a facility, locking systems, protecting the perimeter of the facility and intrusion detection.

Access Control

❖ Access control can be viewed as a central element to Information security (IS).

❖ IS goal (in other words):

- Prevent unauthorized access to information system **resources**.
- Prevent authorized/legitimate users from accessing the **resources** in an unauthorized manner.
- Allow legitimate users access the **resources** in an authorized manner.

• Access control comprises of three concepts:

- Authentication
- Authorization
- Audit

• NOTE:

- Access control = Authentication + Authorization + Audit

Access Control

● Authentication

- Is the process of determining whether a user (or other entity) should be allowed access into a system or not.
- Is the verification that the credentials of a user or other system entity are valid or not.
 - Verifying that an entity is what it claims to be.
 - It's a binary(Yes or No) decision:
 - Access granted (Yes) OR
 - Not granted (No)

● Authorization

- Is the granting of a right or permission to a system entity to use a system resource.
 - Authorization places restrictions on the actions of authenticated users.
 - This function determines who is trusted for a given purpose in the system.
 - Simply concerned with the permissions an entity can have in using a resource.

Access Control

- Audit
 - Is a review and examination of activities performed in a system.
 - The goal of an audit is to:
 - Check the adequacy/effectiveness of system controls/security policies.
 - Check the compliance with established security policies and operational procedures.
 - Detect any security breaches.
 - Recommend changes that will improve security.
 - Simply, it is a process of security check up and improvement of information security policy.

Access Control

- **Authentication:** Are you who you say you are?
 - Are you allowed to access the system at all?
- **Authorization:** Are you allowed to do that?
 - What type of access to resources are you allowed to have in the system.
- **Audit:** monitors and keeps a record of user accesses to system resources.
- **Example: SIMS System**
 - Students + instructors/ Admins(System Administrators, Instructors, HoD, DoS, PoC) may gain access:
 - But who is allowed to do what?

AUTHENTICATION

(User)

User Authentication

- A human can be authenticated to a machine based on any of the following:
 - i. Something you know
 - ii. Something you are
 - iii. Something you have

User Authentication

- A human can be authenticated to a machine based on any of the following:
 - i. Something you know
 - Can be a username, password, PIN, Passphrase
 - This is a cheap approach but not so secure.
 - See:
 - Social engineering – people manipulation (to perform an action/disclose sensitive info.)
 - Phishing - malicious entity disguises as a trustworthy one
 - Password: (advised) should be hard to guess/crack but easy to remember.
 - ii. Something you are
 - ❖ Biometrics – fingerprint, palm, eye (retinal/iris scanning).
 - ❖ This is expensive but more secure.
 - iii. Something you have
 - An ATM card, a smartcard, a phone

User Authentication

- Two-factor Authentication
 - Is any authentication method that requires two out of the three approaches of authentication.
 - Usually raises the level of security.
 - Examples:
 - ATM – have (card), know (password)
 - Door Access – are (thumbprint), know (password)
 - Google Account – know (password), have (phone/SIM card)

Passwords

- ❖ Password is the most common authentication method.
 - ✓ Something you know
- ❖ A **password** is a word or string of characters used for user authentication to prove identity or access approval to gain access to a resource, which is to be kept secret from those not allowed access.
 - ❖ Some passwords are formed from multiple words and may more accurately be called a **passphrase**.
- ❖ The terms **passcode** and **passkey** are sometimes used when the secret information is purely numeric, such as the personal identification number (PIN) commonly used for ATM access.

Passwords

- ❖ Most organizations specify a **password policy** that sets requirements for the composition and usage of passwords.
- ❖ The organizations usually specify the:
 - ✓ Minimum password length.
 - ✓ Required categories/composition (e.g. Upper and lower case, numbers and special characters).
 - ✓ Prohibited elements (e.g. Own name, date of birth, address, telephone number).
- ❖ Some governments have national authentication frameworks.
 - ❖ The frameworks define requirements for user authentication to government services.
 - ❖ This includes requirements for passwords.

Passwords

- ❖ The use of passwords is known to be ancient.
 - ❖ Sentries (guard/watchman) would challenge those wishing to enter an area or approaching it to supply a password or *watchword*, and would only allow a person or group to pass if they knew the password/watchword.
- ❖ In modern times, usernames and **passwords** are commonly used by people during a login process that controls access to protected resources.
 - ❖ The protected resources such as:
 - ✓ Operating systems
 - ✓ Mobile phones
 - ✓ Automated teller machines (ATMs), etc.

Why Passwords?

❖ Why is “something you know” more popular than “something you have” and “something you are”?

- ✓ **Cost**

- ✓ Passwords are free.

- ✓ **Convenience**

- ✓ It is easier for system administrators to reset password than to issue the user a new thumb.

Classic password rules

- ❖ The best passwords are those that are both easy to remember and hard to crack using a dictionary attack.
- ❖ The best way to create passwords that fulfill both criteria is to use two small unrelated words, ideally with a special character and/or number.
- ❖ Good examples would be: *hex7goop* **or** *–typetin* **or** *!Lov3MyPiano*
- ❖ **Don't use:**
 - ✓ Common names, DOB, spouse, phone #, etc.
 - ✓ Word found in dictionaries
 - ✓ Password as a password
 - ✓ Systems defaults

Classic password rules

❖ Use Strong Passwords

- ✓ Passwords are like house keys.
 - ✓ Use a different key for each lock.
- ✓ Associated password risks:
 - ✓ Brute force attacks
 - ✓ Sniffing clear text traffic

❖ SUPR password tests:

- ✓ Strong – Password strength (length and content)?
- ✓ Unique – Unique and unrelated to other passwords?
- ✓ Practical – Can you remember it?
- ✓ Recent – Have you changed it recently?

PASSWORD MANAGEMENT

- ❖ Configure system to use strong passwords
- ❖ Set password lifetime and lengths limits
- ❖ Limit number of unsuccessful logins
- ❖ Enabled auditing
- ❖ Have policies for password resets and changes

Problems with passwords

❖ Insecure passwords

- ❖ Given the choice, people will choose easily remembered and hence easily guessed passwords such as names of relatives, phone numbers, birthdays, hobbies, etc.

❖ Easily broken passwords

- ❖ There are programs that can be used to easily crack passwords.
 - ❖ Dictionary attacks are only feasible/possible because users choose easily guessed passwords.

❖ Inconvenience of passwords

- ❖ In an attempt to improve security, organizations often issue users with strong computer-generated passwords that are difficult, if not impossible to remember.

❖ NOTE: Other password issues include:

- ❖ Failure to change default passwords.
- ❖ Social engineering.

Attacks on Passwords

❖ The bottom line: **Weak Password cracking is too easy!**

- ✓ One weak password may break the whole security

- ✓ Passwords are a **big** security problem

❖ **Attacker could...**

- ✓ Target one particular account

- ✓ Target any account on a system

✓ Password attacks include:

1. Guessing

2. Dictionary Attacks

3. Brute force attacks

4. Social Engineering

Techniques for guessing passwords

- ❖ Try default passwords.
- ❖ Try all short words, 1 to 3 characters long.
- ❖ Try all the words in an electronic dictionary(60,000).
- ❖ Collect information about the user's hobbies, family names, birthday, etc.
- ❖ Try user's phone number, social security number, street address, etc.
- ❖ Try all license plate numbers (T103 AAA).

How to avoid Guessable passwords?

❖ Techniques used to avoid guessable passwords.

❖ Four technique can be used:

1. **User education**
2. **Computer-generated passwords**
3. **Reactive password checking**
4. **Proactive password checking**

How to avoid Guessable passwords?

1. User education

- Users can be told the importance of using hard-to-guess passwords and can be provided with guidelines for selecting strong passwords.

2. Computer-generated passwords

- Users can be provided with strong passwords generated by a computer algorithm.

3. Reactive password checking

- The system periodically runs its own password cracker to find guessable passwords.
 - The system cancels any passwords that are guessed and notifies the user.

4. Proactive password checking

- A user is allowed to select his or her own password.
 - However, at the time of selection, the system checks to see if the password is allowable and, if not, rejects it.

Password Cracking Tools

- Popular password cracking tools
 - ✓ Password Crackers (Medusa, Hydra , ...)
 - ✓ L0phtCrack and LC4 (Windows)
 - ✓ John the Ripper (Unix)
- NOTE:
 - System admins should use these tools to test for weak passwords since attackers will.
- Good article on password cracking
 - ✓ Passwords - **Cornerstone** of Computer Security
 - ✓ Link:
<https://community.broadcom.com/symantecenterprise/communities/community-home/librarydocuments/viewdocument?DocumentKey=656f46ef-9e3c-4c1e-a629-594d76fb5339>

Password protection

- Two common techniques used to protect a password file:
 - **One-way encryption**
 - The system stores only an encrypted form of the user's password.
 - When the user presents a password, the system encrypts that password and compares it with the stored (encrypted) value.
 - In practice, the system usually performs a one-way transformation (not reversible).
 - The password is used as an input to the encryption function and a fixed-length output is produced.
 - **Access control**
 - Access to the password file is limited to one or very few accounts.

Password Storage

- Passwords should never be stored in plain text.
 - Reason:
 - If an attacker manages to gain access to the passwords, all the associated accounts can be accessed by the attacker.
- Passwords should be stored in the form of their hashed values.
 - A hash function is used to achieve this.
 - A hash function is a one-way (irreversible) function that takes an input data of any length and produces an output of fixed length.
 - Storing passwords in their hashed form makes it hard for an attacker to know the stored passwords.

Password Storage

- Challenge:
 - If the users use weak passwords, the attacker with access to the hashed passwords can eventually reveal the passwords.
 - The attacker can use dictionary words and the hash function to create a hash for each word and check if the produced hash exists in the discovered file of password hashes.
 - Therefore, Hashing plaintext passwords is not enough.
 - If two users use the same password, the passwords will have the same hash values.
 - A compromise to one account can lead to a compromise in the other account.
 - The solution:
 - Use **salt** in the hashing function.

Password Storage

- The solution:
 - Use **salt** in the hashing function.
 - Salt: Is a value that is added to the input of a hash function to create a unique hash for every input, regardless of the input not being not being unique.
 - As a result this a security compromise associated with usage of same password by several users.
 - This is done by the system/application, not the user.
- The salt helps in the following ways:
 - ✓ Prevents duplicate passwords, even if two users choose the same password.
 - ✓ Effectively increases the strength of the password.

Something You Are

Biometric



Biometrics

- ❖ This is about authenticating a user by using human characteristics.
- ❖ This uses measurable physical characteristics of a person to prove their identity.
 - ❖ Examples: Fingerprint, Facial recognition, Speech recognition, Iris, Retina, DNA.
- ❖ Biometrics seen as desirable replacement for passwords.
 - ❖ But cheap and reliable biometric devices are needed.
- ❖ Biometrics are used in security today
 - ❖ Palm print for secure entry, Fingerprint to unlock car door, etc.
- ❖ But biometrics not too popular.

Practical biometric applications

- ❖ Biometrics can be used for:
 - ❖ Staff time and attendance tracking.
 - ❖ Authorizing financial transactions.
 - ❖ Government benefits distribution verification (Social Security, welfare, etc.).
 - ❖ Verifying identities at point of sale.
 - ❖ Used in conjunction with ATM , credit or smart cards.
 - ❖ Controlling physical access to office buildings or homes.
 - ❖ Protecting personal property.

Fingerprint Biometric

❖ Advantages of fingerprint-based biometrics

- ✓ Can't be lent like a physical key or token and can't be forgotten like a password.
- ✓ Good compromise between ease of use, cost and accuracy.
- ✓ Fingerprint enable unique identification even in very large (millions of records) databases.
- ✓ Makes authentication/authorization effortless.

Biometrics: The Bottom Line

- Biometrics are hard to forge.
- But attacker could
 - ✓ Steal Alice's thumb
 - ✓ Photocopy Bob's fingerprint, eye, etc.
- **Biometrics are not foolproof!**
- Biometric use is limited today
- That should change in the future...

MULTI-FACTOR AUTHENTICATION

- Requires 2 out of 3 of
 1. Something you know
 2. Something you have
 3. Something you are
- **Examples**
 - ✓ ATM machine: ATM Card and PIN
 - ✓ Credit card: Card and signature
 - ✓ Smartcard with password/PIN

MULTI-FACTOR AUTHENTICATION

- **2-factor authentication:** To increase the level of security, many systems will require a user to provide 2 of the 3 types of authentication.
 - ❖ ATM card + PIN
 - ❖ Credit card + signature
 - ❖ PIN + fingerprint
 - ❖ Username + Password (Unix, NT default)
- **3-factor authentication:** For highest security
 - ❖ Username + Password + Fingerprint
 - ❖ Username + Passcode + SecurID token



END

ET 8202 LECTURE 05